Автономная некоммерческая организация высшего образования
«Санкт-Петербургский институт экономики и управления»



Кафедра **09.02.07 Информационные системы и программирование**

ПРАКТИЧЕСКАЯ РАБОТА № 3

Дисциплина(модуль)/предмет **МДК.03.02**

Тема: **Аудит исходного C# кода**

ВАРИАНТ № **3**

Студент (ка)/учащийся: **Бойцов Даниил Антонович** / _____ /
Ф. И. О. подпись

Группа / Класс **И13-24-11**

Руководитель: **Чудинова А.А.** /_____ /
Должность, степень, Фамилия и инициалы подпись

Дата представления работы «04» ноября 2026 г.

Работа аттестована с оценкой _____
прописью

Санкт-Петербург
2026 г.

Содержание

1 Объект и методика аудита.....3
2 Протокол выявленных несоответствий 4
3 Чек лист соответствия после исправлений.....5
Подтверждающие материалы 6
Заключение 7
Список использованных источников 8

1 Объект и методика аудита

Цель работы: выявить нарушения стиля, структуры, логики и требований документации в модуле Climate Control. Проверены LegacyClimateController, защищённый TelemetryController, HmacHandler, TelemetryValidator и ТЗ. Исходная Legacy-заготовка создана для учебного аудита; отдельного исходного кода варианта в задании нет.

Заготовка размещена в samples/Climate.Before как библиотека и не подключена к маршрутам рабочего API. Использованы чтение кода, машинный чек-лист и воспроизведение проблемных значений. Координаты находок и SHA-256 проверенных файлов записаны в evidence/static-audit.json.

Проверки разделены на три основания. Стиль имён и XML-комментарии оцениваются по принятому регламенту C# и рекомендациям Microsoft [1]. Логика и безопасность проверяются по R01–R08. ГОСТ 19.201-78 применяется к ТЗ, а не используется как источник правил PascalCase [2].

```
public IActionResult send(string id, decimal t, decimal h, int seq)
{
  // Фрагмент учебной заготовки
  if (t >= -40 || t <= 85)
  {
    data.Add(new LegacyReading(id, t, h, seq));
    return Ok();
  }
  return BadRequest();
}
```

Условие с || истинно для любого decimal: значение ниже -40 всё равно меньше 85, а значение выше 85 всё равно больше -40. Требуется пересечение границ через &&. Само исправление этого условия не добавляет HMAC, права или защиту от повтора.

2 Протокол выявленных несоответствий

Код	Наблюдение	Основание и действие
AUD01	Методы send, count, report названы с маленькой буквы.	Стиль C#: перейти к PascalCase и содержательным именам.
AUD02	У публичного метода нет XML summary и описания параметров.	Проектный регламент документации: добавить контракт и результат.
AUD03	Диапазон температуры задан логическим объединением.	R03: заменить на пересечение и добавить граничные тесты.
AUD04	Влажность сохраняется без допустимого интервала.	R03: отдельная проверка 0..100 % через валидатор.
AUD05	Источник и целостность сообщения не подтверждаются.	R01/R04: HMAC и серверная политика доступа.
AUD06	Контроллер владеет списком данных и диагностическими сообщениями.	Разделение обязанностей: вынести сервис, хранилище и диагностику.

Контрольный вызов заготовки с температурой 100 °C и влажностью 250 % возвращает OkResult. Два xUnit-сценария B01 фиксируют такое ошибочное поведение; их успешное выполнение означает воспроизведение дефекта, а не правильность заготовки. Исправленный валидатор и API проверяются отдельно.

SQL-инъекция не заявляется найденной в Legacy-коде: SQL там отсутствует. Для нового relational-хранилища выполнена профилактическая проверка параметризации EF Core. Это позволяет отличить доказанную находку от возможного риска дальнейшей разработки.

3 Чек лист соответствия после исправлений

Проверка	**До**	**После**
PascalCase публичных методов	Не соответствует	Соответствует: Post, Send, Accept.
XML-контракт целевого API	Не соответствует	Соответствует для TelemetryController.Post.
Диапазоны температуры и влажности	Не соответствует	Соответствует: FluentValidation и граничные тесты.
Подлинность и целостность	Не соответствует	Соответствует проверенному HMAC-контракту.
Разделение транспортной и предметной логики	Требует доработки	Валидатор, аутентификация и EF-хранилище отделены.
Содержание ТЗ по ГОСТ 19.201	Требует доработки	Оформлены восемь основных разделов.
Постоянный защищённый аудит и общий nonce-кэш	Не соответствует промышленному контуру	Требует доработки для нескольких узлов и перезапуска.

Машинный чек-лист подтвердил summary, имя Post, Authorize Policy, подключение валидатора, проверку владельца, Rate Limiting и восемь разделов ТЗ. Проверка отдельных признаков не заменяет чтение логики; поэтому дополнительно сохранены результаты реальных unit и интеграционных испытаний.

Статус после исправлений относится к указанному объёму. Заключение не является сертификацией всего продукта по ГОСТ Р 56939. Управление ключами, долговременный аудит и аппаратная проверка требуют самостоятельных эксплуатационных мероприятий.

Подтверждающие материалы

Рисунок 1 дополняет материалы работы. На снимке приведён фрагмент журнала статического аудита. Идентификаторы AUD01–AUD04 связывают наблюдения с протоколом несоответствий в отчёте.

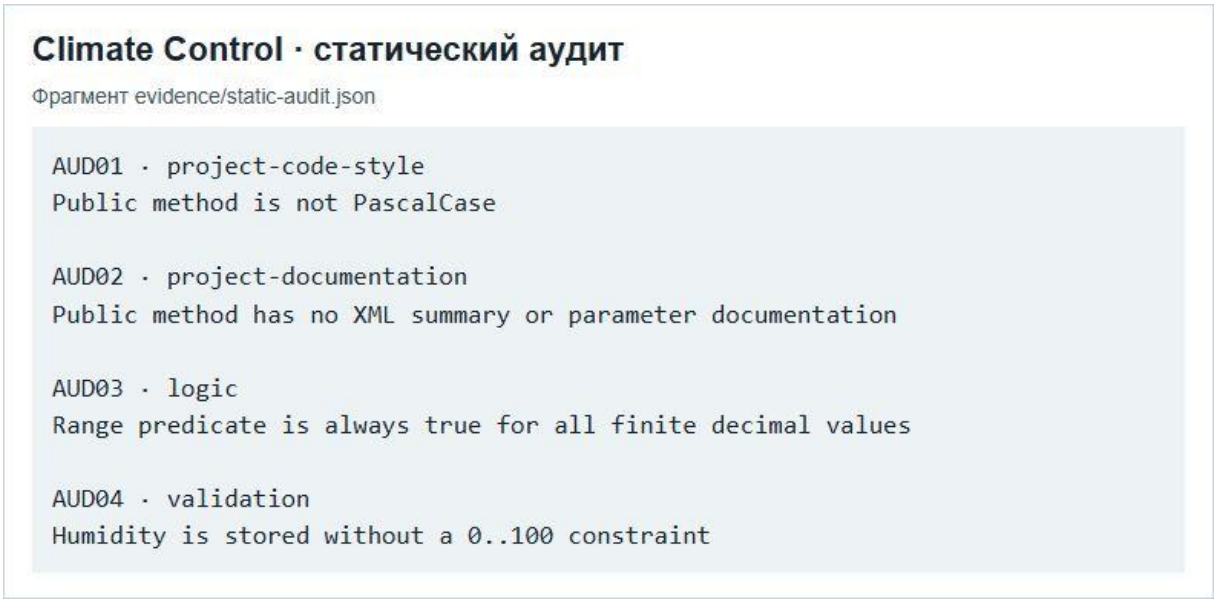


Рисунок 1 — Фрагмент статического аудита Climate Control

Материалы работы на GitHub: открыть раздел работы

Заключение

Зафиксированы шесть конкретных несоответствий с основаниями исправления. Логическая ошибка воспроизведена, требования документации отделены от стиля языка, а результат повторной проверки отражён без скрытия оставшихся эксплуатационных задач.

Материалы относятся к модулю Climate Control варианта 3. Проверенный программный стенд не подключён к физическому отоплению или вентиляции кампуса. Промышленная приёмка оборудования в рамках работы не проводилась.

Список использованных источников

1. Microsoft Learn. C# identifier naming rules and conventions. URL: https://learn.microsoft.com/en-us/dotnet/csharp/fundamentals/coding-style/identifier-names.

2. Росстандарт. ГОСТ 19.201-78. Техническое задание. Требования к содержанию и оформлению. URL: https://protect.gost.ru/gost/details/b64061cf-6bb2-4c75-aee9-18bb5e26e554.

3. Росстандарт. ГОСТ Р 56939-2024. Разработка безопасного программного обеспечения. Общие требования. URL: https://protect.gost.ru/gost/details/f3818925-a96f-4f55-96e9-46b44720ee64.